Local-Area Network (LAN) Attacks

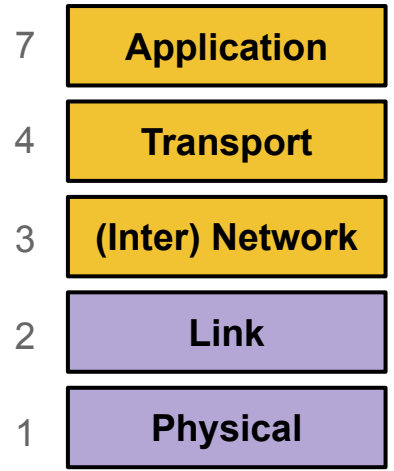
CS 161 Spring 2026 - Lecture 25

Send me requests for
April 15 bonus lecture:
`henrycg.com/feedback`

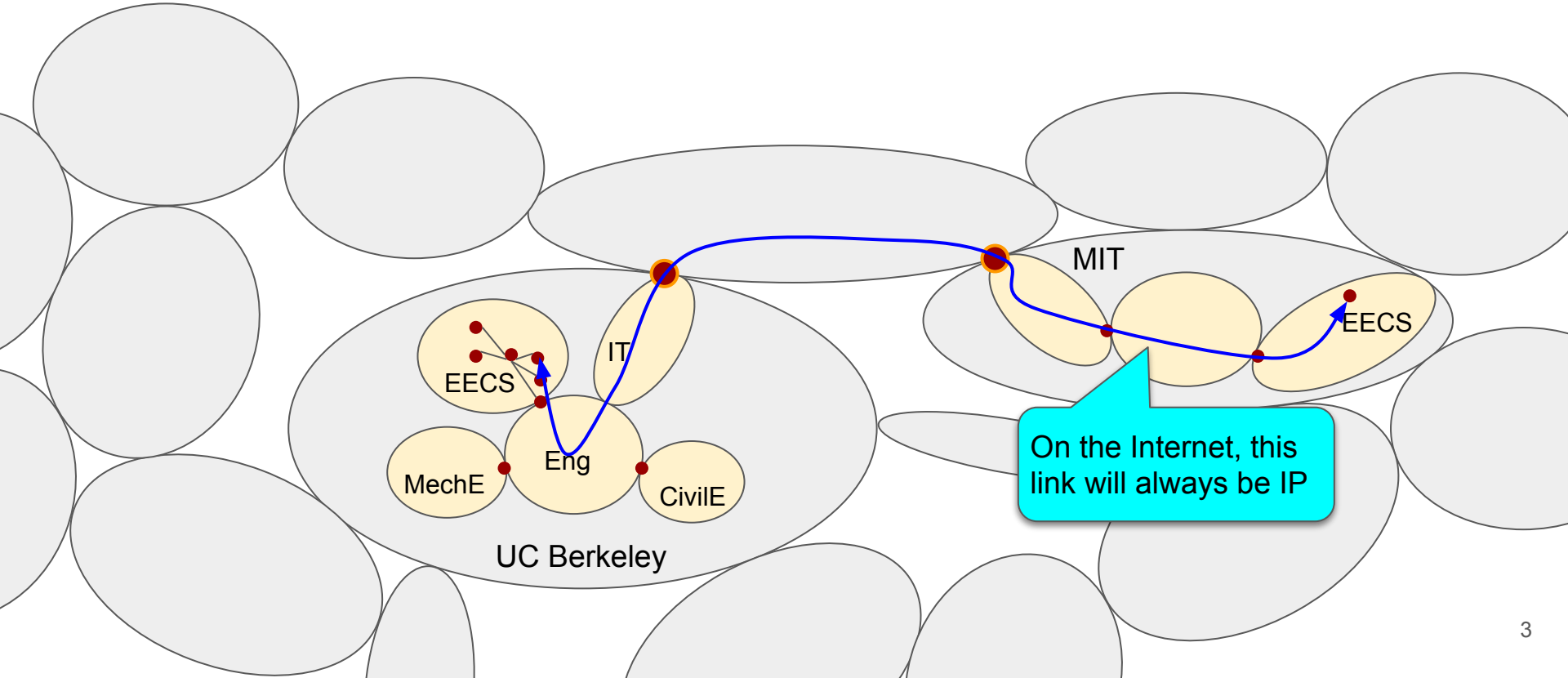
Recap: Intro to Networking

Protocols are in layers:

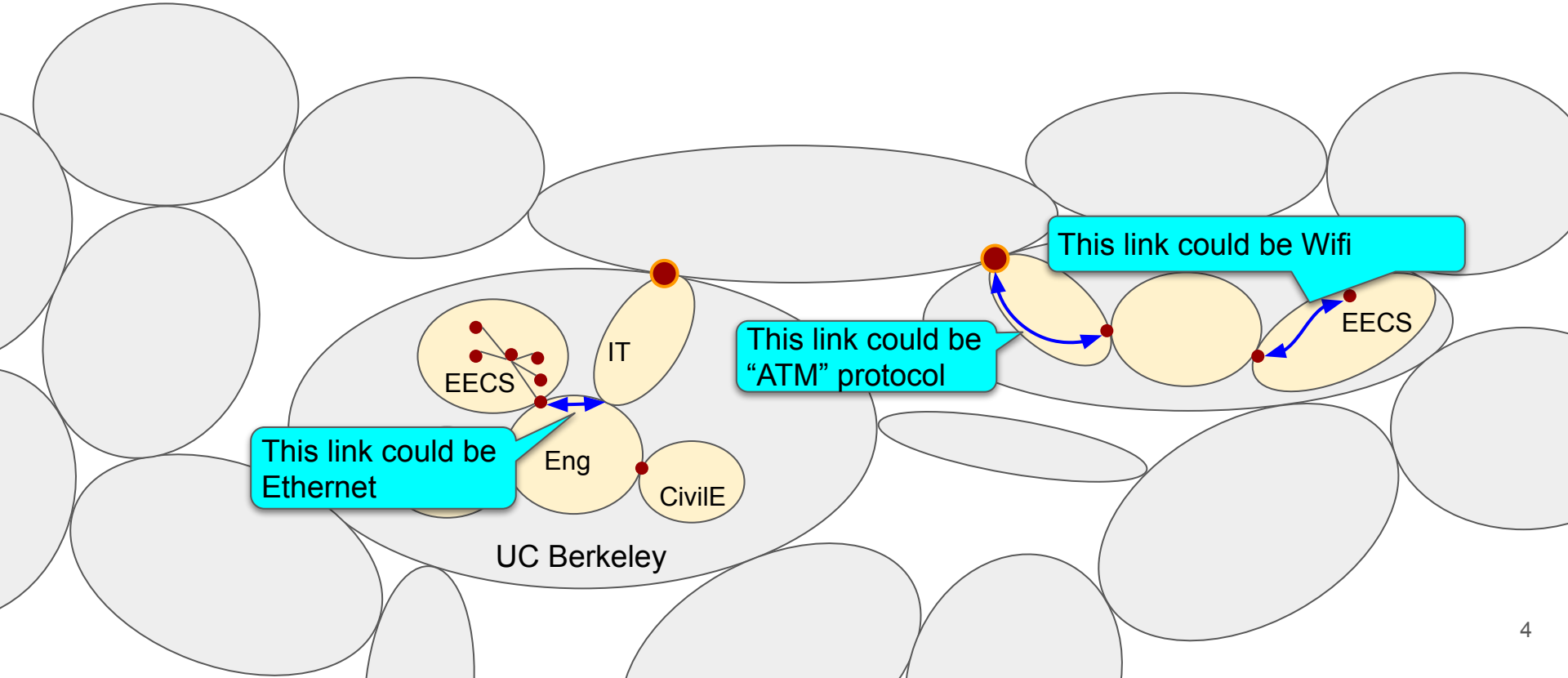
- Layer 7: Applications and services — HTTP, SSH, …
  - Address: Depends on protocol — (e.g., for HTTP: /files/stuff.jpg)
- Layer 4: Transport of data — TCP, UDP
  - Address: 16-bit port number — (e.g., port 80)
- Layer 3: Global packet delivery — IP
  - Address: 32-bit string (IPv4), — (e.g., 10.7.12.130)
- Layer 2: Local frame delivery — Ethernet, Wifi
  - Address: 6-byte string (Ethernet) — (e.g., 4e:05:6c:9a:aa:5a)
- Layer 1: Physical communication — Radio waves, light



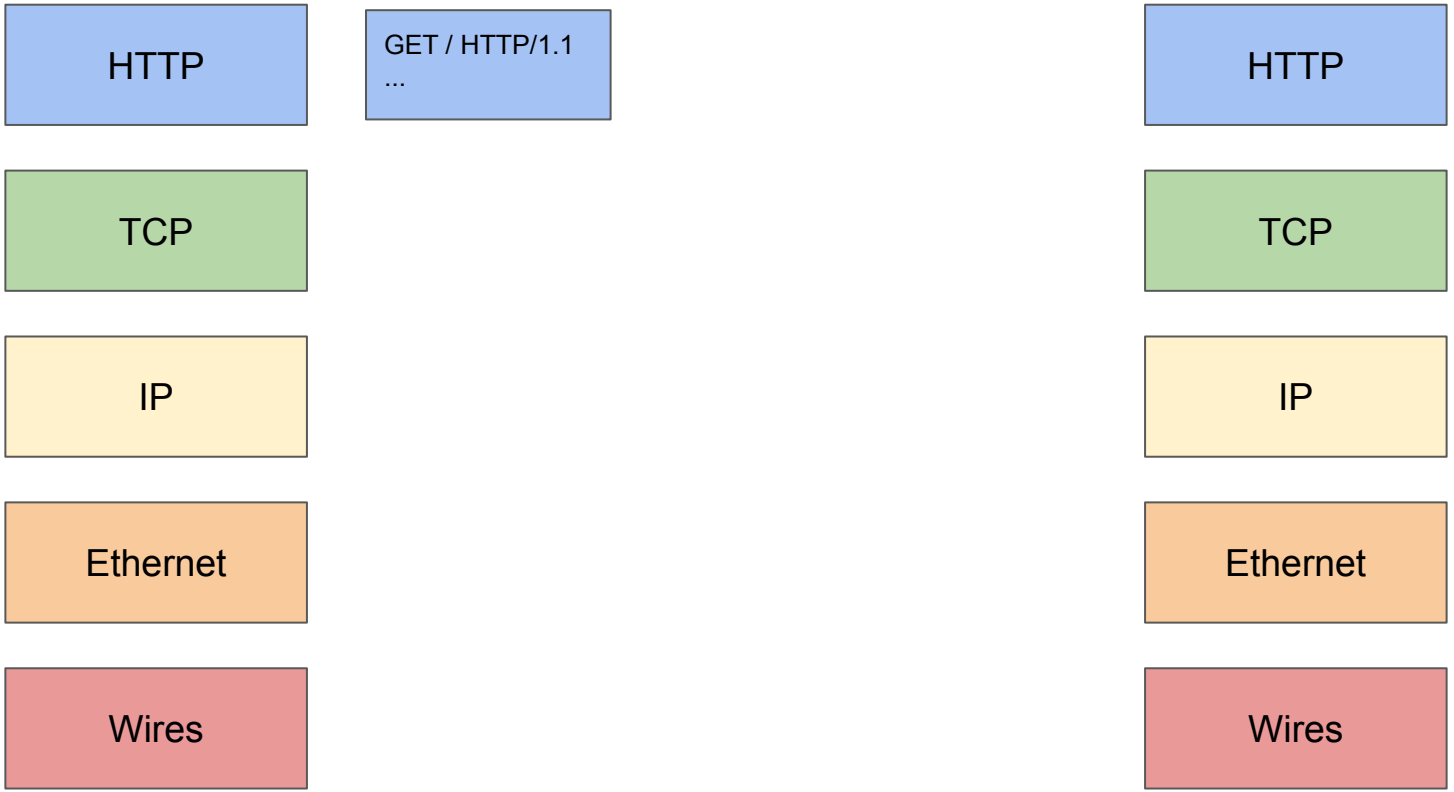
Layer 3: IP connects faraway points on the Internet



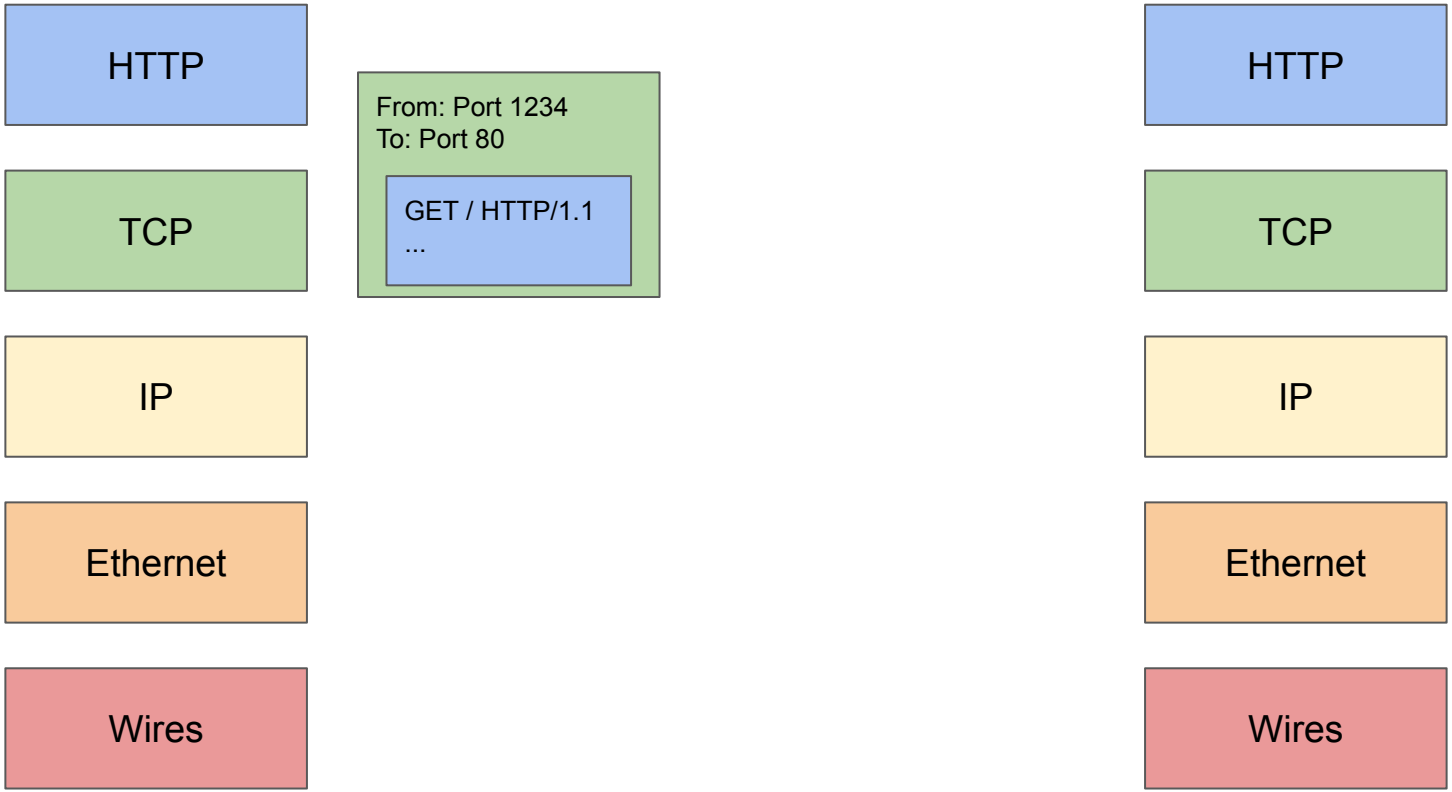
Layer 2: Ethernet (+ others) connects hosts in local network



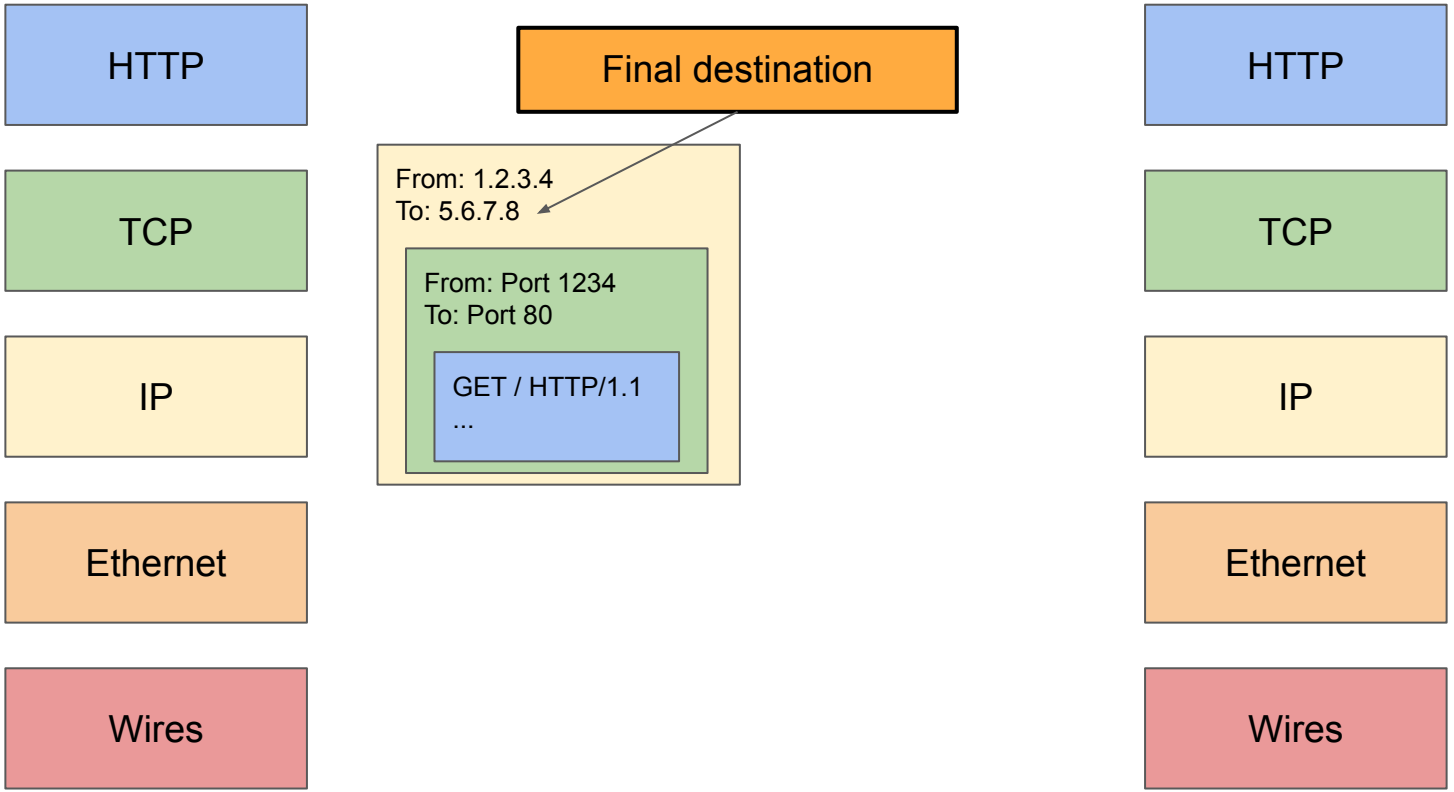
Example: HTTP Request



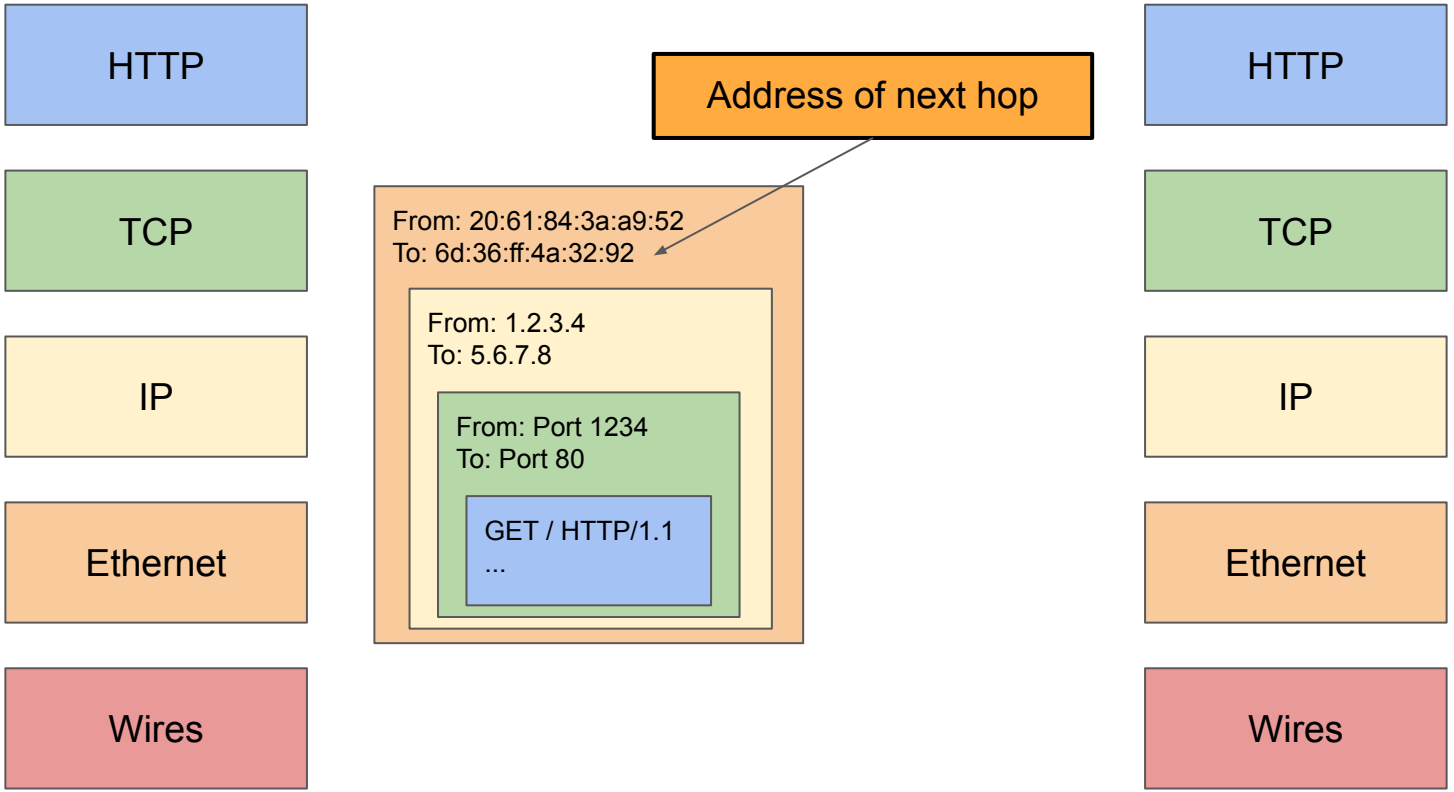
Example: HTTP Request



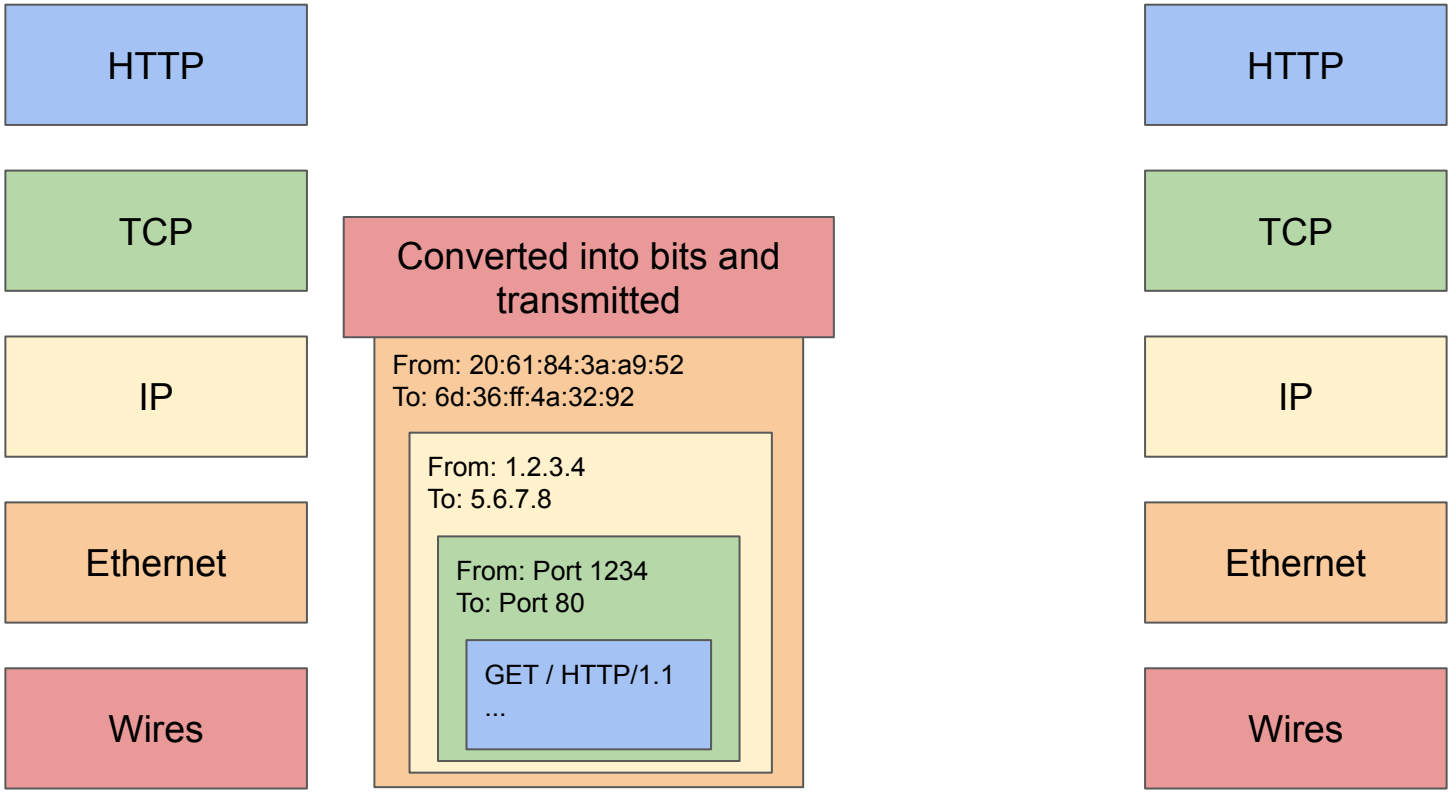
Example: HTTP Request



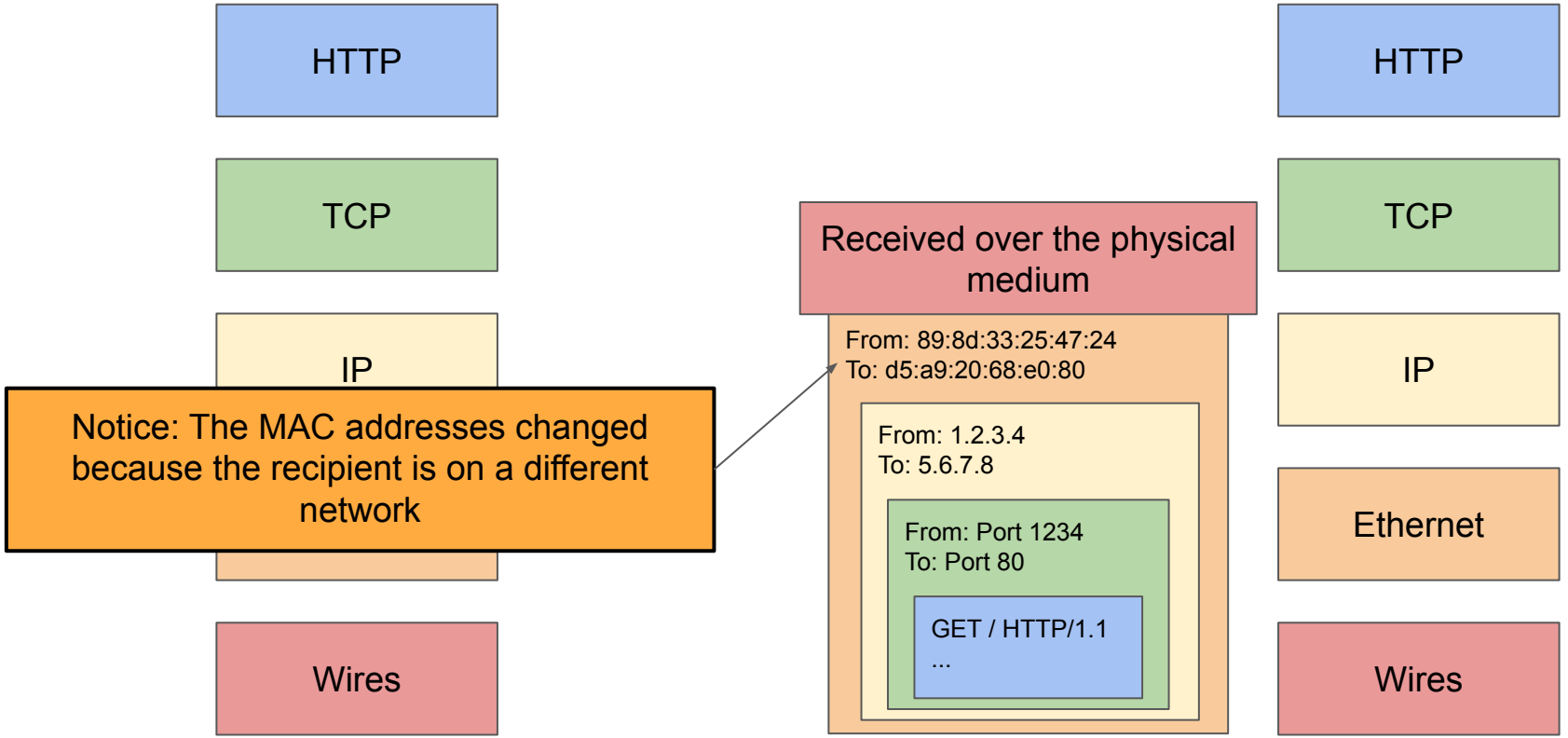
Example: HTTP Request



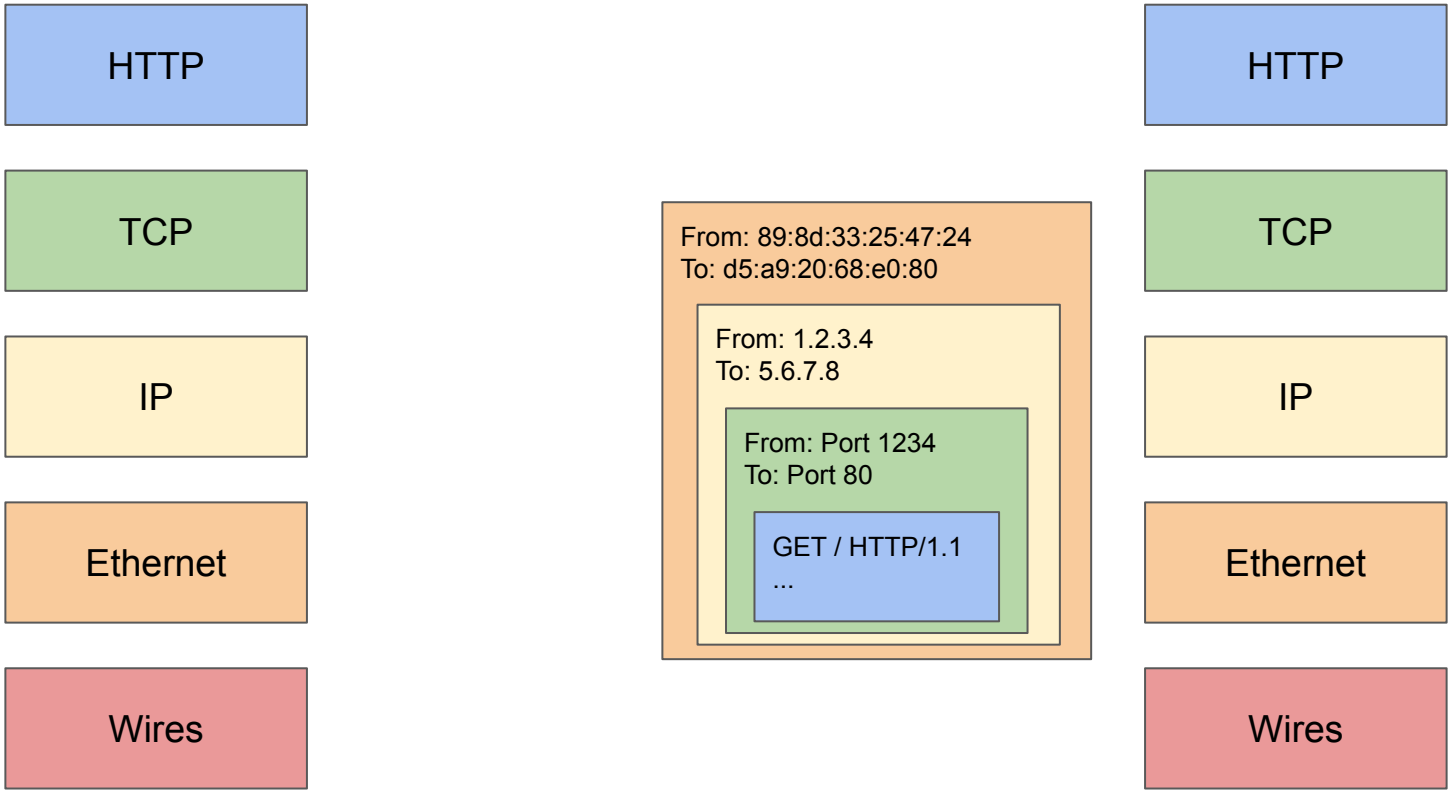
Example: HTTP Request



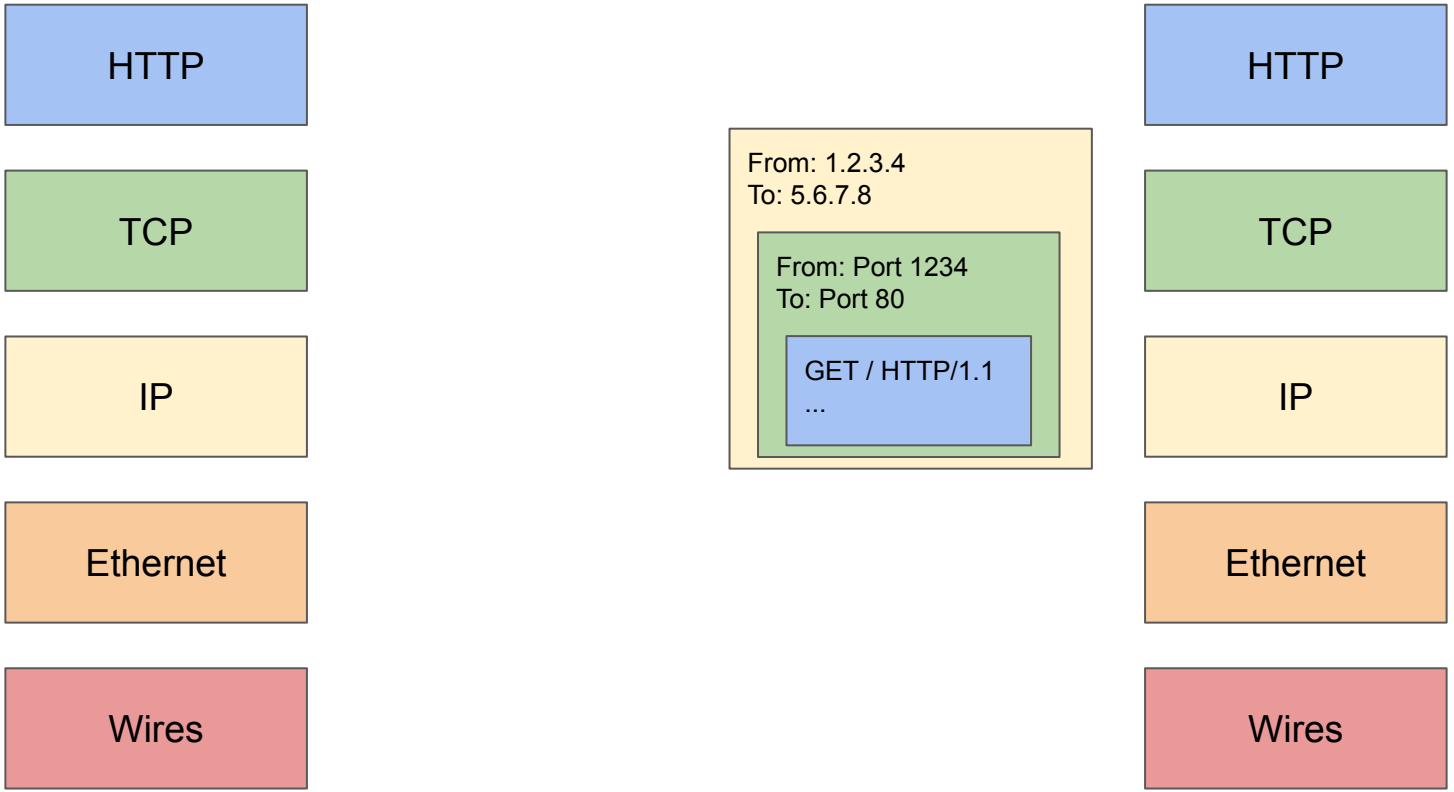
Example: HTTP Request



Example: HTTP Request



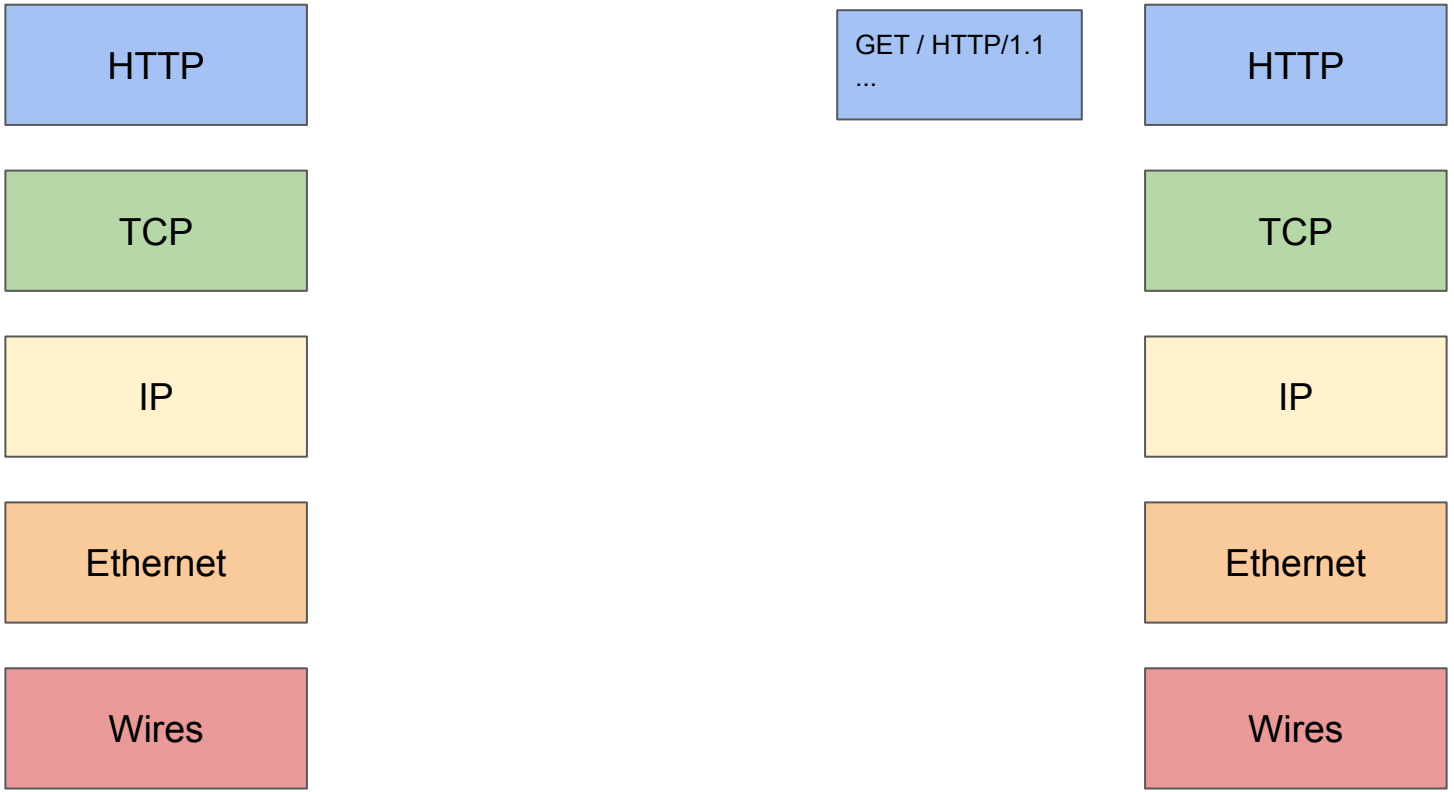
Example: HTTP Request



Example: HTTP Request



Example: HTTP Request

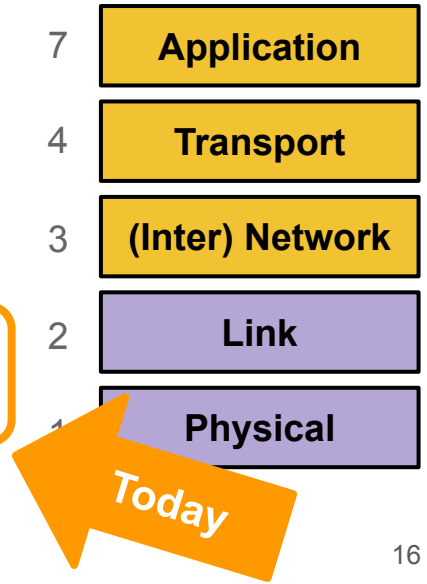


Show `wireshark`

Recap: Intro to Networking

Protocols are in layers:

- Layer 7: Applications and services — HTTP, SSH, …
  - Address: Depends on protocol — (e.g., for HTTP: /files/stuff.jpg)
- Layer 4: Transport of data — TCP, UDP
  - Address: 16-bit port number — (e.g., port 80)
- Layer 3: Global packet delivery — IP
  - Address: 32-bit string (IPv4), — (e.g., 10.7.12.130)
- Layer 2: Local frame delivery — Ethernet, Wifi
  - Address: 6-byte string (Ethernet) — (e.g., 4e:05:6c:9a:aa:5a)
- Layer 1: Physical communication — Radio waves, light



Today: Local-Area Network (LAN) Attacks

- Against widely used protocols:
  - ARP: Translate IP addresses to MAC addresses
  - WPA: Communicate securely in a wireless local network
  - DHCP: Get configurations when first connecting to a network

- All of these require the attacker to be on your LAN

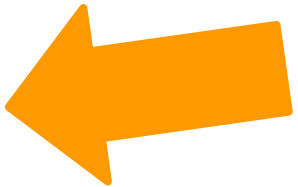
How an attacker joins your LAN



Mounting LAN attack requires being on LAN

Two ways for attacker to join your LAN:

1) Physically connect to your network

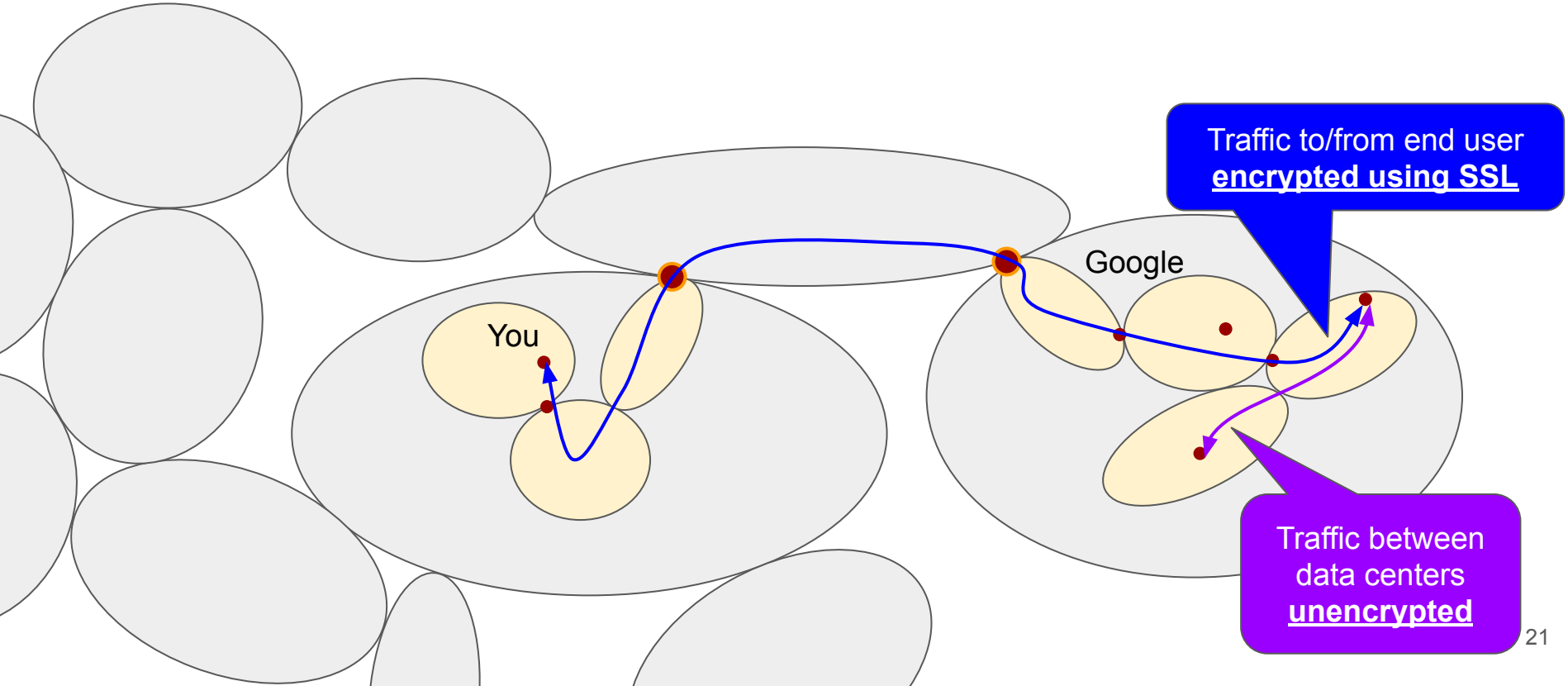


2) Take over a machine already on your network

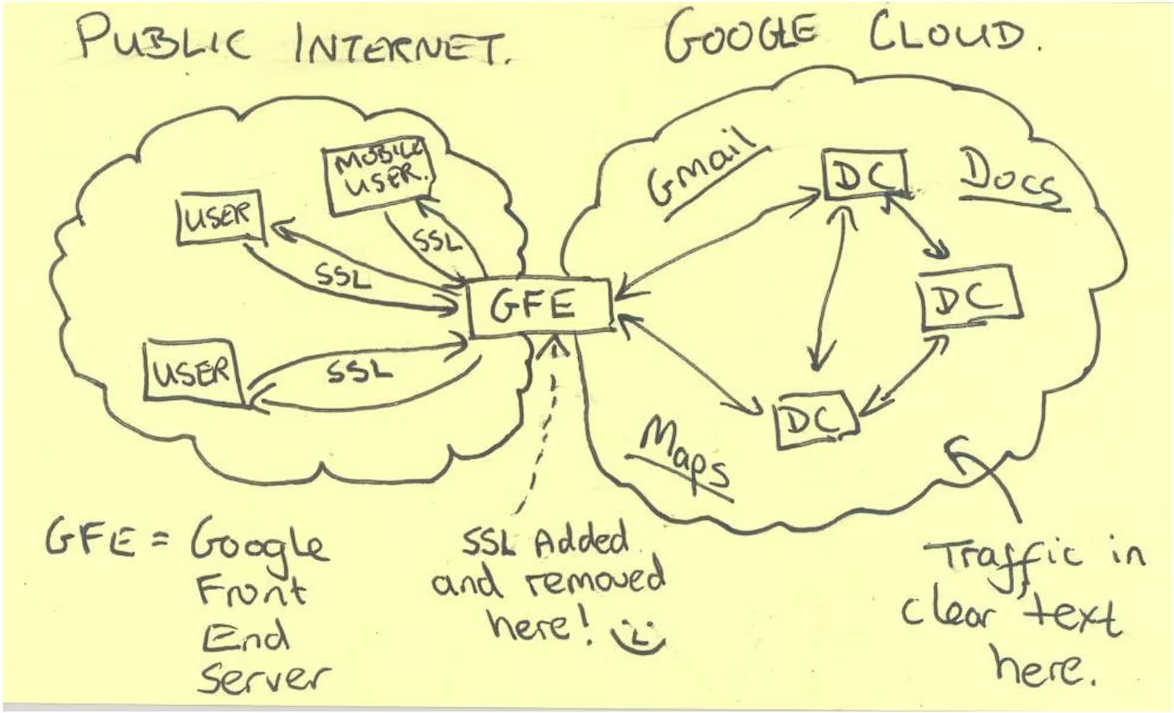
Threat: Attacker joins your local-area network

- Joining LAN requires physical network access
  - Old days: Being plugged into your Ethernet hub
  - Now: Having access to your wifi network
- Seems hard/expensive for attacker to get on your network
- Gives rise to the risky assumption: **“Attacker cannot join my LAN”**
- As a result, companies often do not encrypt/authenticate data on LAN:
  - E.g., between two Google data centers
  - E.g., for backhaul network between cell towers

Example: Google pre-2013



Current Efforts - Google



Real-World On-Path Attackers

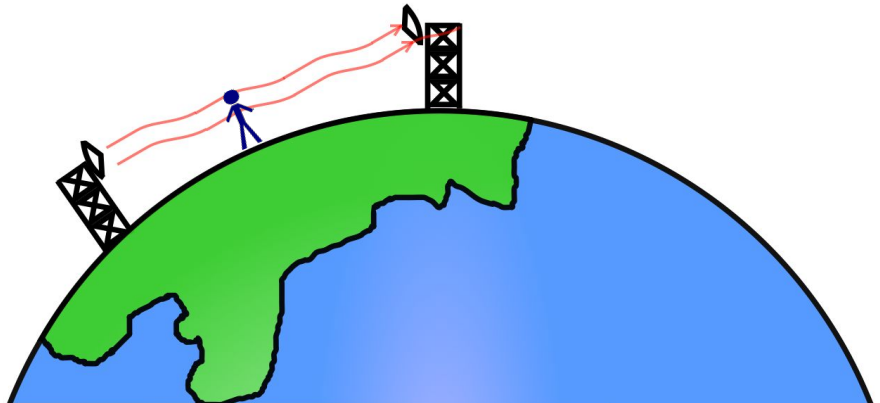
Military.com

Operation Ivy Bells

Matthew Carle *February 6, 2017*

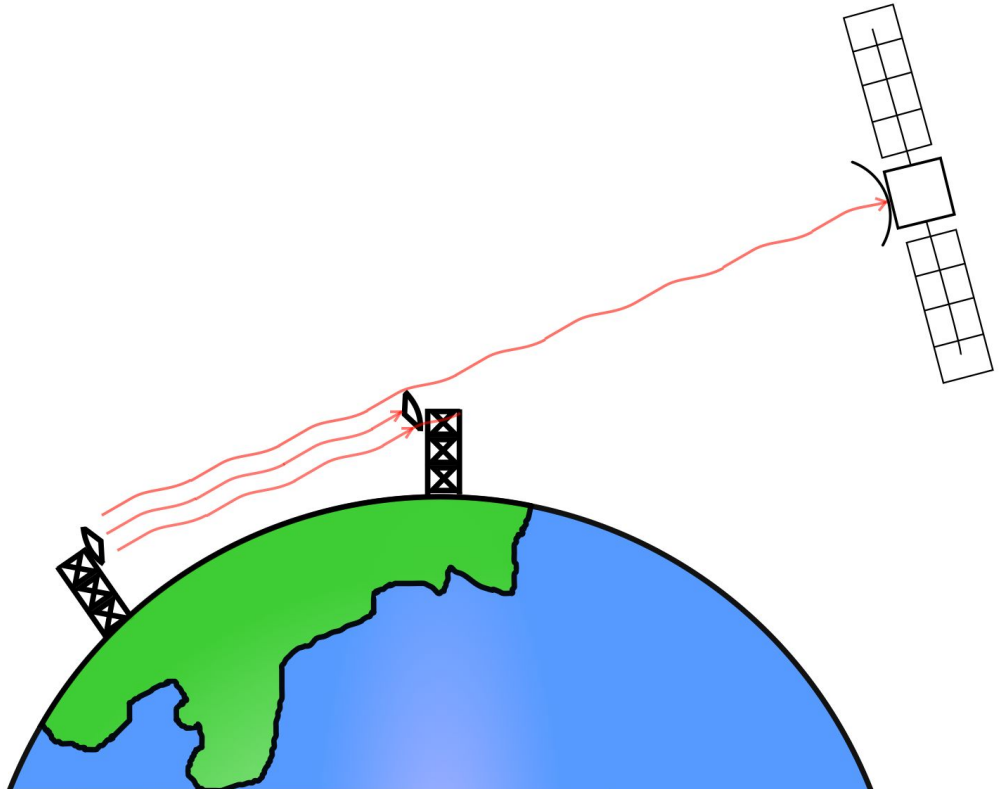
In an effort to alter the balance of the Cold War, divers from the USS Halibut scoured the ocean floor for a five-inch diameter cable that carried secret Soviet communications between military bases. The divers found the cable and installed a listening device. Upon their return to the United States, the NSA analyzed the recordings and found that a surprising amount of sensitive Soviet information travelled through the lines without encryption. The original tap was later discovered by the Soviets and is now on exhibit at the KGB museum in Moscow.

RHYOLITE



https://commons.wikimedia.org/wiki/File:Rhyolite_sat.svg

RHYOLITE



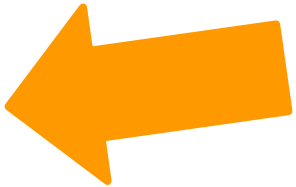
https://commons.wikimedia.org/wiki/File:Rhyolite_sat.svg

Mounting LAN attack requires being on LAN

Two ways for attacker to join your LAN:

1) Physically connect to your network

2) Take over a machine already on your network



→ MUCH more common today

→ Basic idea: Get someone on the network to install malware

→ Doesn't require travel, physical hardware, etc.

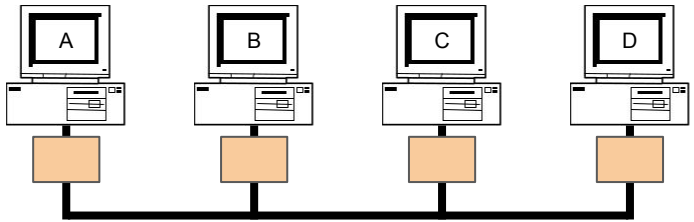
Moral of the story

- LAN attacks requires controlling a machine on the network
- But clever attackers can get machines on your network
- So, you might need to worry about LAN attacks

Background: Ethernet

- **Recall:** Ethernet is a protocol used to connect computers in a LAN
  - E.g., computers in one office (or part of an office)

- Traditionally, Ethernet hosts were connected to a “shared broadcast medium”
  - The only way to send a message to someone was to broadcast it to *everyone* in the LAN
  - Honest nodes should ignore messages not for them 🤔
  - Modern Ethernet “switches” improve the situation somewhat



Ethernet spoofing

- **Spoofing**: Pretending that you are someone else
  - Example: Mallory sends a message and says the message is from Alice
  - The attacker can lie about the *source address* in the packet header

- It is easy to spoof Ethernet packets
  - Just like it's easy to put whatever return address you want on a piece of mail
  - On common OSes, spoofing requires root access on the machine
  - Using Ethernet/MAC address for authentication is not very robust

- ⇒ When you get an Ethernet packet, you only know that it came from *someone* on your local-area network
  - On open wifi networks, this is not a terribly meaningful guarantee

Address Resolution Protocol (ARP)

Address Resolution Protocol (ARP)

- **ARP**: If you know someone's IP address and want their MAC address
  - Example: Visiting a web server on your local network
  - Example: Finding out MAC address of your home wifi router (so that you can browse internets)

- Steps of ARP:
  1. Alice checks her cache to see if she already knows Bob's MAC address.
  2. If Bob's MAC address is not in the cache, Alice **broadcasts** to everyone on the LAN:
     "What is the MAC address of `1.2.3.4`?"
  3. Bob responds to Alice:
     "My IP is `1.2.3.4` and my MAC address is `ca:fe:f0:0d:be:ef`."
     Everyone else does nothing.
  4. Alice caches Bob's MAC address.

Address Resolution Protocol (ARP)

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC

Alice

Bob

Charlie

Dave

Router

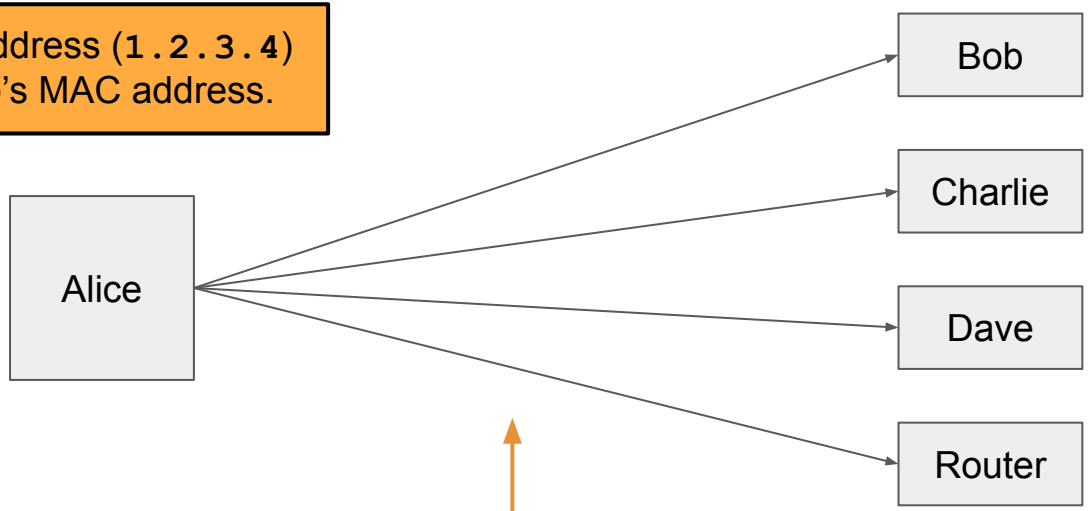
1. Alice checks her cache to see if she already knows the MAC address corresponding to `1.2.3.4`.

Since her cache is empty, she must make a request to find out.

Address Resolution Protocol (ARP)

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC



2. Alice asks everyone else on the local network: "What is the MAC address of `1.2.3.4`?"

Address Resolution Protocol (ARP)

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC





3. Bob responds: "My IP is `1.2.3.4` and my MAC address is `ca:fe:f0:0d:be:ef`."

Everybody else ignores the request.

Address Resolution Protocol (ARP)

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC
`1.2.3.4`	`ca:fe:f0:0d:be:ef`

Alice

Bob

Charlie

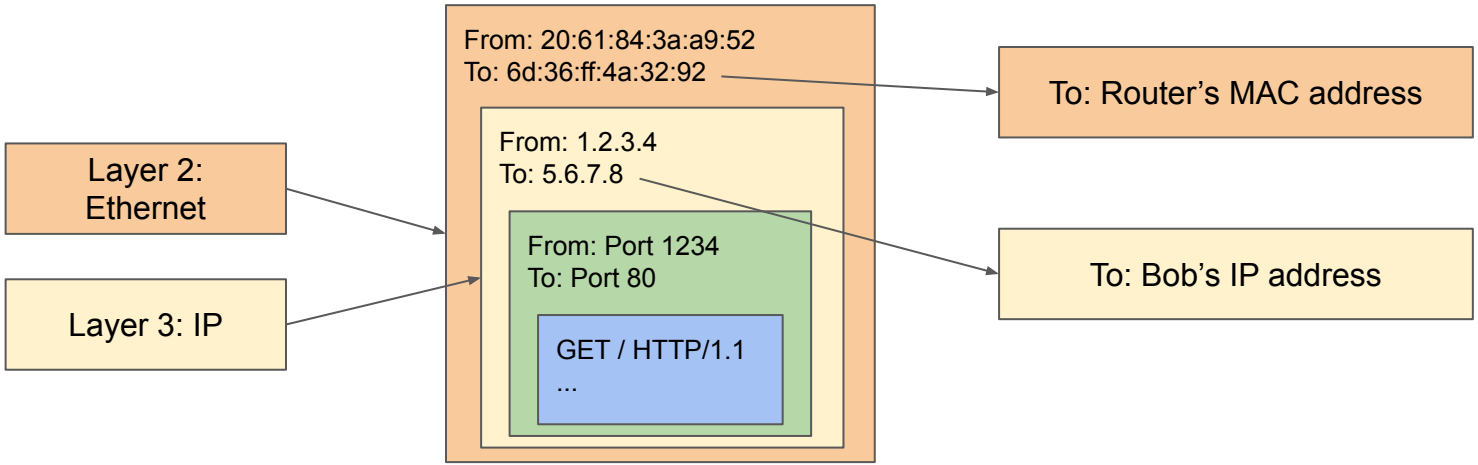
Dave

Router

4. Alice adds Bob's MAC address to her cache.

Address Resolution Protocol (ARP)

- If Bob is outside of the LAN, the router will respond with its own MAC address
  - If Alice wants to send a packet to Bob, she sends the packet to the router
  - The router can forward the packet to other LANs to reach Bob
  - Alternatively, if Alice knows what addresses belong to the LAN, she will request the MAC address that corresponds to the router's IP
- All received ARP replies are cached, even if no request was sent… why?



Attacks on ARP

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC

Alice

Bob

Charlie

Mallory

Router

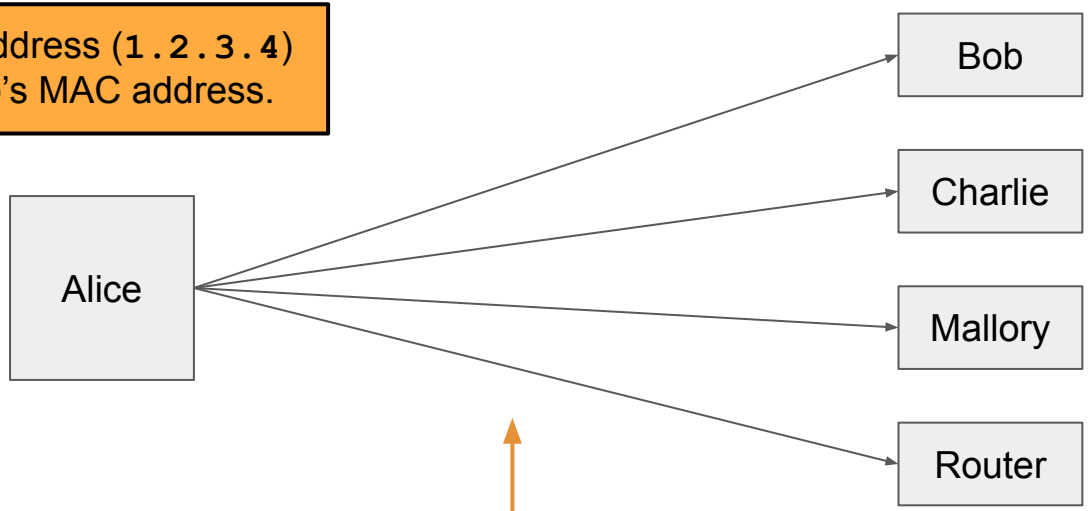
1. Alice checks her cache to see if she already knows the MAC address corresponding to `1.2.3.4`.

Since her cache is empty, she must make a request to find out.

Attacks on ARP

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC

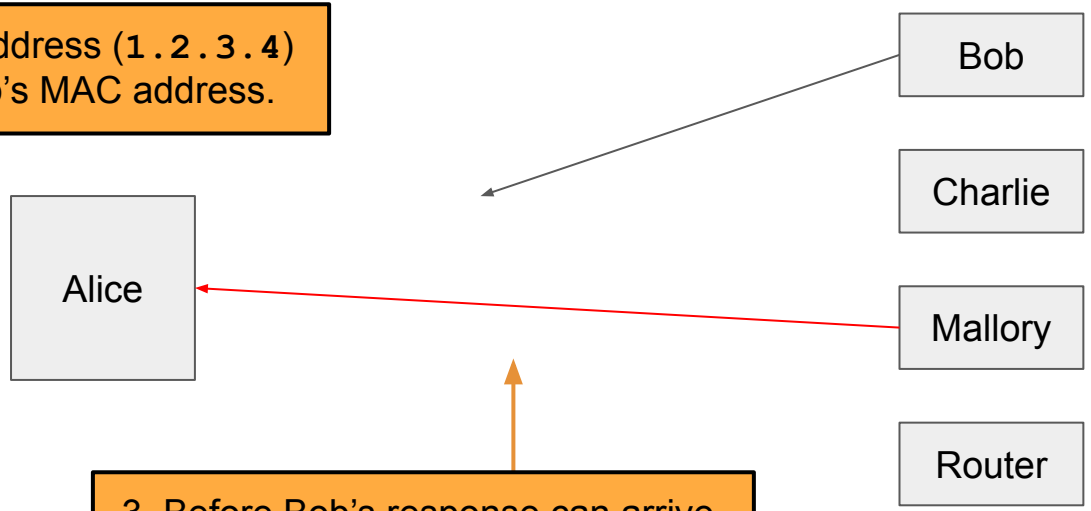


2. Alice asks everyone else on the local network: "What is the MAC address of `1.2.3.4`?"

Attacks on ARP

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC



3. Before Bob's response can arrive, Mallory sends a malicious response: "My IP is `1.2.3.4` and my MAC address is `66:66:66:66:66:66`."

Attacks on ARP

Alice knows Bob's IP address (`1.2.3.4`) but wants to learn Bob's MAC address.

Alice's cache	
IP	MAC
`1.2.3.4`	`66:66:66:66:66:66`

Alice

Bob

Charlie

Mallory

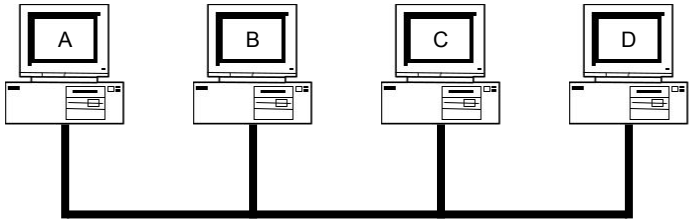
Router

4. Alice adds Mallory's malicious address to her cache.

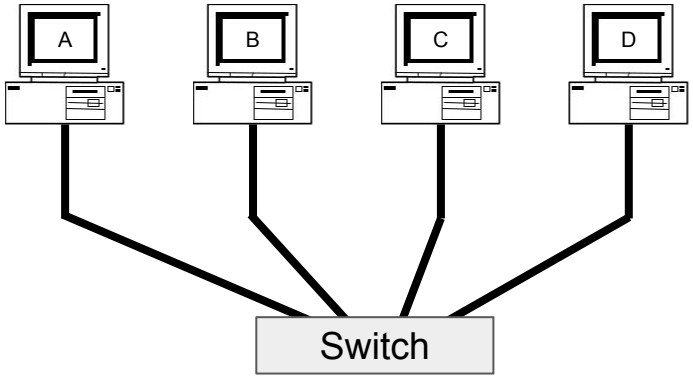
Attack: ARP Spoofing

- Alice has no way of verifying the ARP response
  - Spoofing: Any attacker on the local network can claim to have the requested IP address
- Alice will accept a response from anyone on the network
  - [Alice's exact behavior depends on her networking stack, but this is standard behavior]
- ARP spoofing requires Mallory to be in the same LAN as Alice
- ARP spoofing lets Mallory become a man-in-the-middle (MITM) attacker
  - Alice thinks that Bob's MAC address is `66:66:66:66:66:66` (Mallory's MAC address)
  - When Alice sends a message to Bob, she is actually sending the message to Mallory
  - Mallory can modify the message and then send the modified message to Bob

Defenses against ARP attacks



Old-style networks
use Ethernet “hubs”



Modern networks
use switches

ARP Spoofing: Defenses

- Use **switches** to avoid broadcasts
  - The switch maintains a cache of IP/MAC mappings
  - If Bob's MAC address is in the cache, the switch sends the message directly to Bob
  - Otherwise, the switch broadcasts the message
  - **Still:** Anyone can spoof packets, but switch can detect spoofing honest users' traffic

- Benefits of switches
  - Security: Reduces the number of messages broadcast to the entire LAN
  - Efficiency: Fewer broadcast requests means more requests can be sent per second
  - Isolation: Smarter switches implement virtual local area networks (VLANs), which split a LAN into several isolated parts
    - One part of the VLAN cannot directly interact with other parts of the VLAN

Dynamic Host Configuration Protocol (DHCP)

DHCP: Initial Network Configuration

- To connect to a network, a user needs:
  - An IP address so that other people can contact the user
  - The IP address of the DNS server (we'll see this soon)
  - The IP address of the router (gateway) so that the user can contact machines outside of the LAN
- The first time a user connects, they don't have this information yet
  - The user also doesn't know who to ask for this information
- **DHCP** gives the user a configuration when they first join the network

Steps of the DHCP Handshake

1. **Client Discover:** The client broadcasts a request for a configuration

2. **DHCP Offer**: Any DHCP server can respond with a configuration offer
   - Usually only one DHCP server responds
   - The offer includes an IP address for the client, the DNS server's IP address, and the (gateway) router's IP address
   - The offer also has an expiration time (how long the user can use this configuration)

3. **Client Request**: The client broadcasts which configuration it has chosen
   - If multiple DHCP servers made offers, the ones that were not chosen discard their offer
   - The chosen DHCP server gives the offer to the client

4. **DHCP Acknowledgement**: The chosen server confirms that its configuration has been given to the client

Dynamic Host Configuration Protocol (DHCP)

Alice's configuration	
My IP	???
DNS Server	???
Gateway	???

Alice

Bob

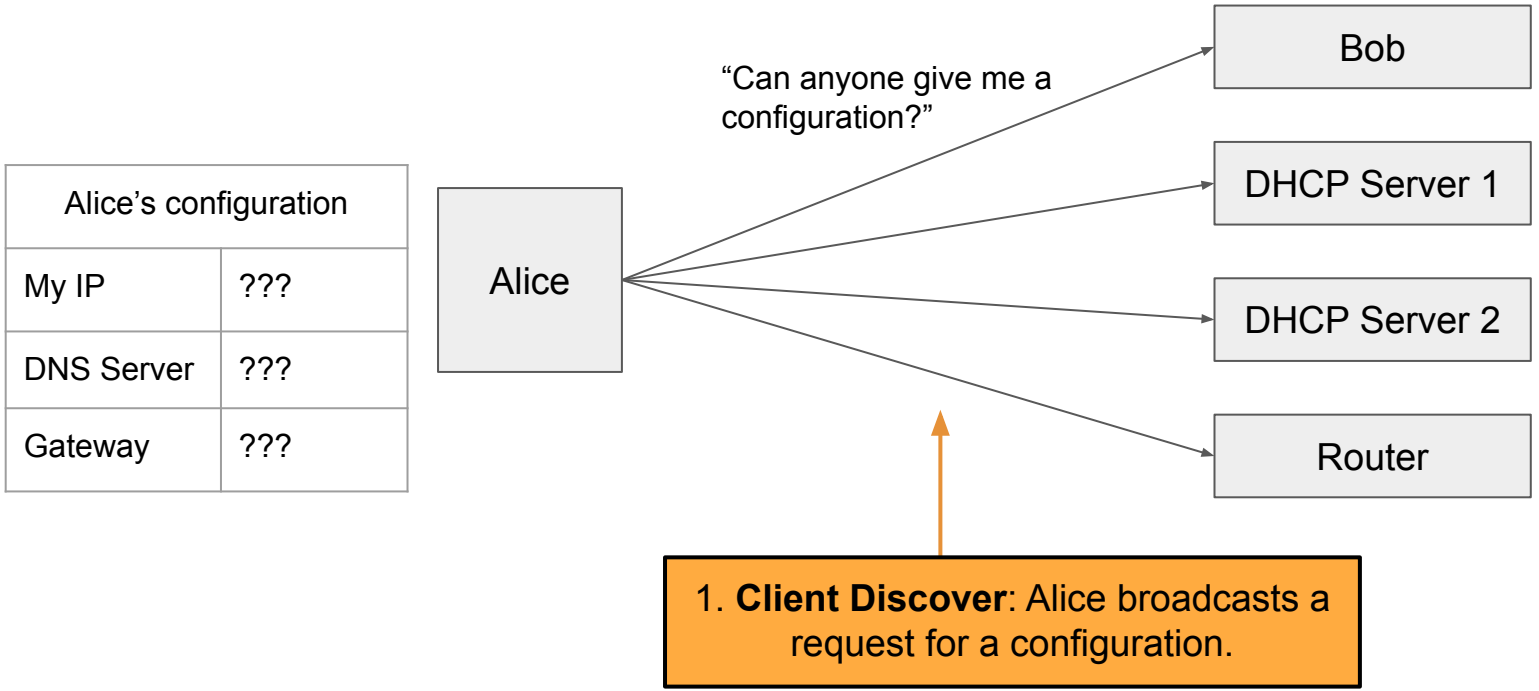
DHCP Server 1

DHCP Server 2

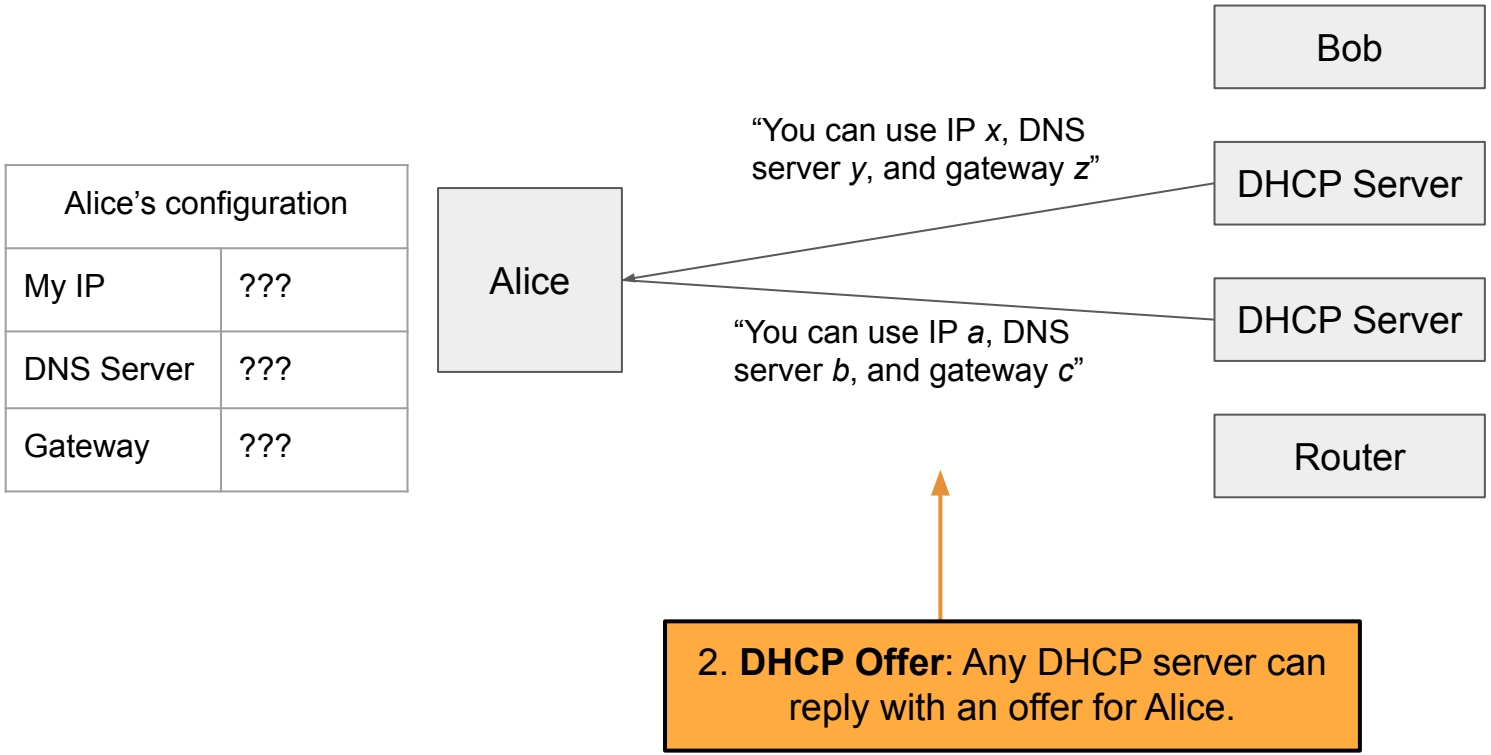
Router

Alice wants to connect to the network, but she's missing a configuration.

Dynamic Host Configuration Protocol (DHCP)

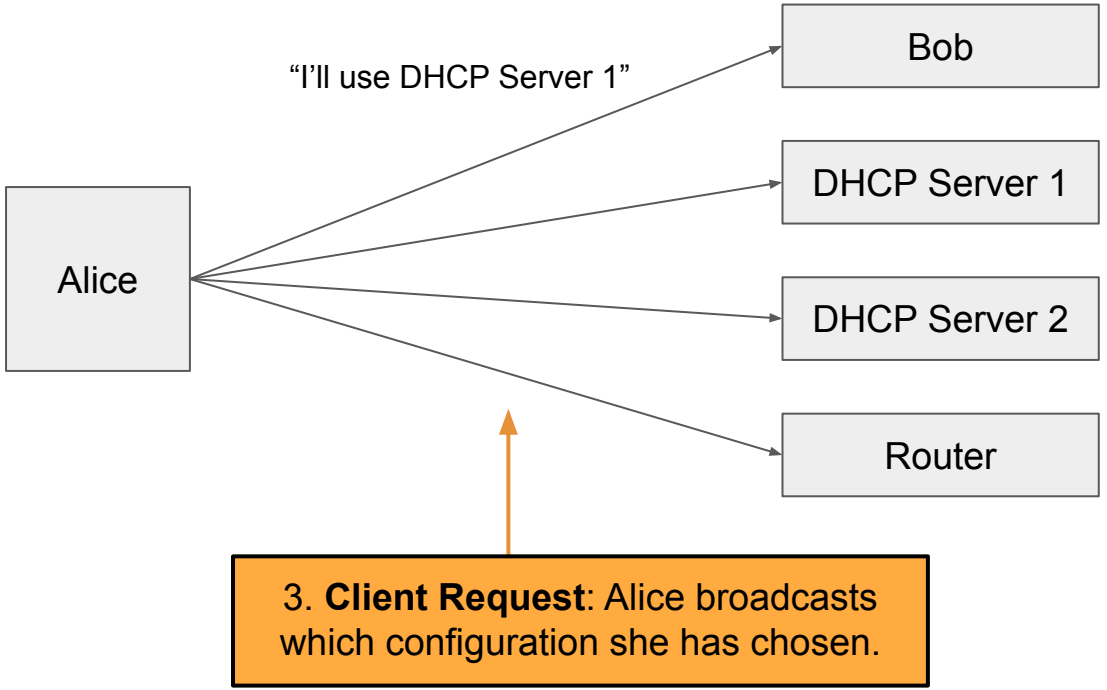


Dynamic Host Configuration Protocol (DHCP)

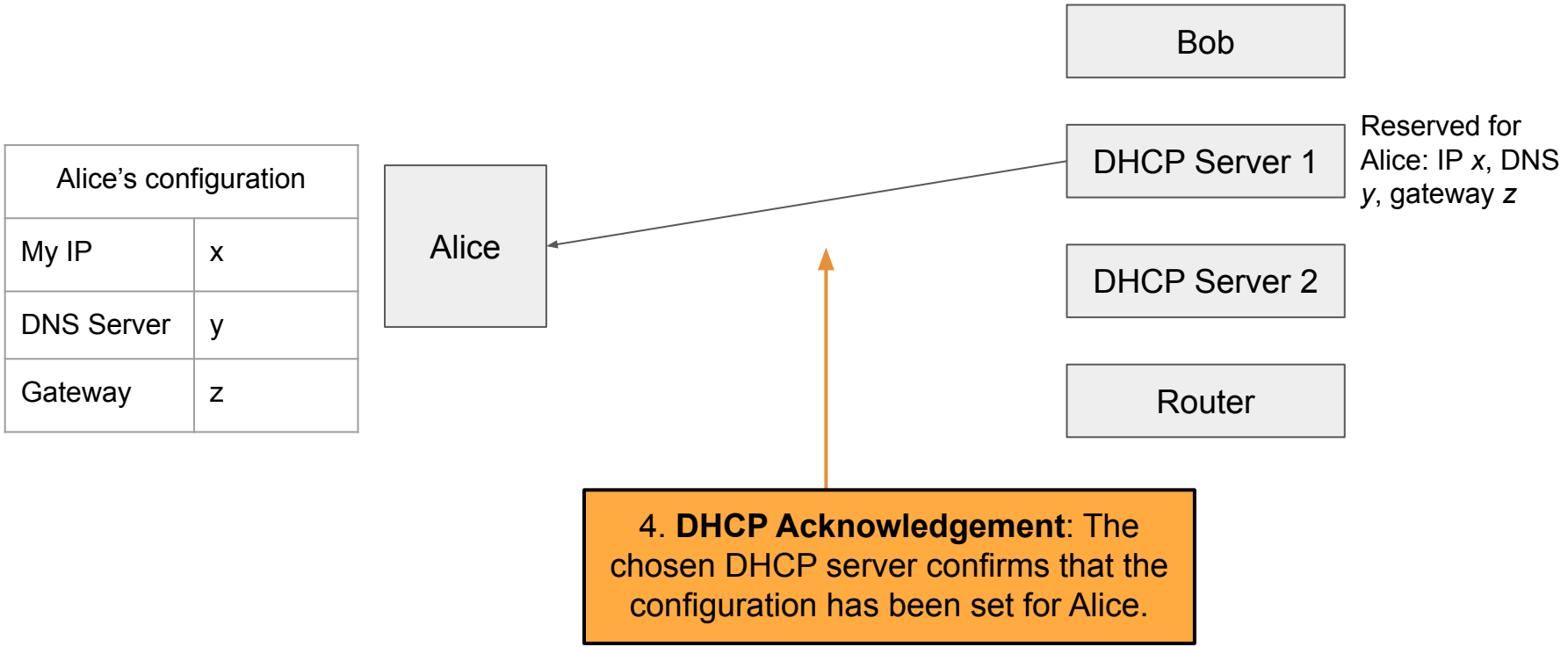


Dynamic Host Configuration Protocol (DHCP)

Alice's configuration	
My IP	???
DNS Server	???
Gateway	???



Dynamic Host Configuration Protocol (DHCP)

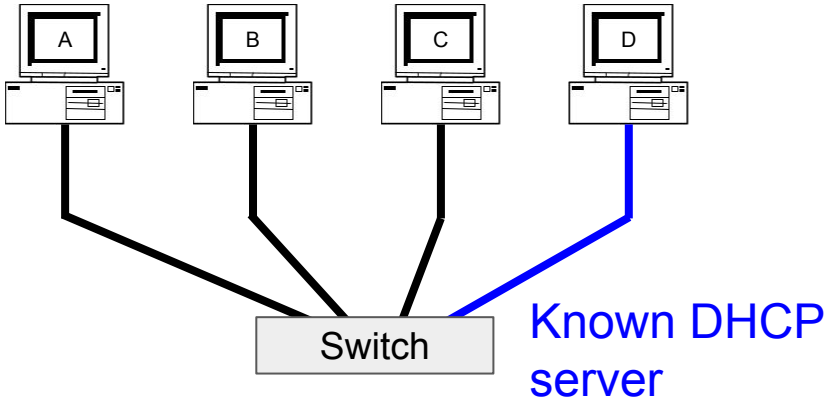


DHCP Attacks

- Alice has no way of verifying the DHCP response
  - Spoofing: Any attacker on the local network can claim to have a configuration
- Alice will accept the first response
  - **Race condition**: As long as the attacker responds faster, Alice will accept the attacker's response
- DHCP attacks let Mallory see and tamper with Alice's IP traffic
  - Mallory claims the gateway router's address is Mallory's address
    - When Alice tries to send a message to the rest of the Internet, she actually sends it to Mallory
    - Mallory can modify the message before sending it to its destination
  - Mallory can also claim the DNS server's address is Mallory's address

DHCP Defenses

- Use a smart switch that supports "DHCP snooping"
  - Switch knows where the real DHCP server is (which port on switch)
  - Drops all DHCP responses from other machines on the network
- Usually you would only see this in corporate networks



ARP and DHCP

- The attacks on ARP and DHCP are very similar
  - Spoofing: The attacker claims to have an answer,
    tricks honest party into accepting wrong answer

- Main issues
  - Broadcast: Requests are sent to everyone on the LAN, so the attacker can see every request
  - No authentication: There is no way to verify that responses are legitimate

- Defense: Fancier network switches
  - Can detect and block fishy traffic

Wireless Local Networks



Wi-Fi

- **Wi-Fi**: A layer 2 protocol that wirelessly connects machines in a LAN
  - Alternative is Ethernet, which uses wires to connect machines in a LAN

- Parts of a Wi-Fi network
  - **Access point**: A machine that will help you connect to the network
  - **SSID**: The name of the Wi-Fi network
  - Password: Optionally, a password to secure Wi-Fi communications

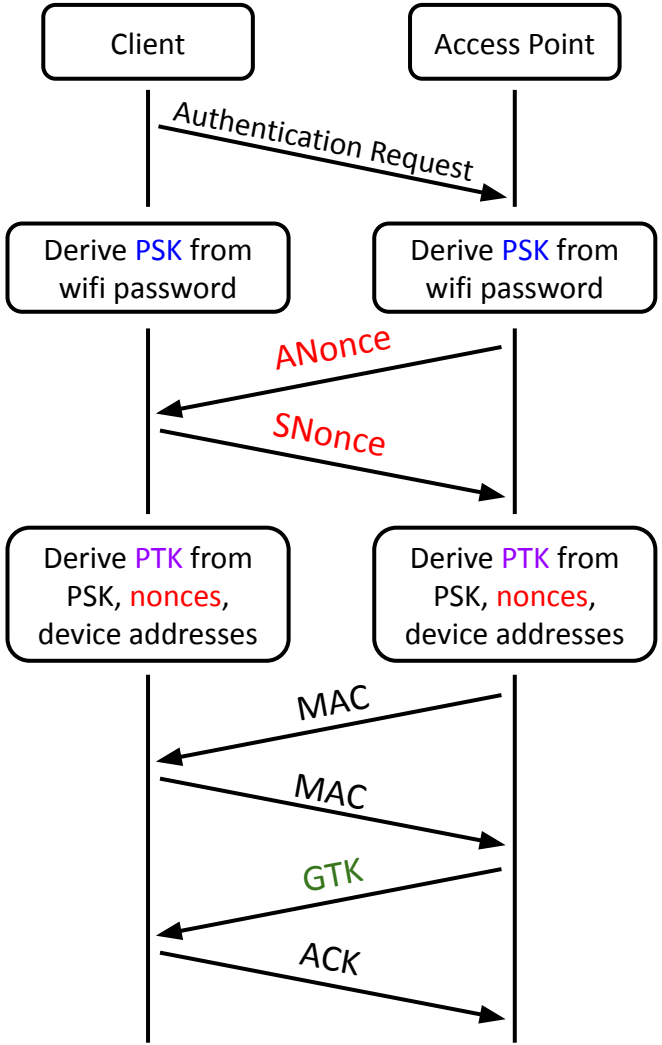
WPA2

- **Wi-Fi Protected Access 2** (**WPA2**):
  A protocol for securing Wi-Fi network communications with cryptography

- Design goals
  - Everyone with the Wi-Fi password can join the network
  - Messages sent over the network are encrypted with keys
  - An attacker who does not know the Wi-Fi password cannot learn the keys

WPA Handshake

1. The client sends an authentication request to the access point
2. Both use the password to derive the *PSK* (pre-shared key)
3. Both exchange random nonces
4. Both use the *PSK*, nonces, and device addresses to derive the *PTK* (pairwise transport keys)
5. Both exchange MACs to ensure no one has tampered with the nonces, and that the PTK was correctly derived
6. The access point encrypts and sends the *GTK* (group temporal key) to the client, used for broadcasts that anyone can decrypt
7. The client acknowledges receiving the GTK

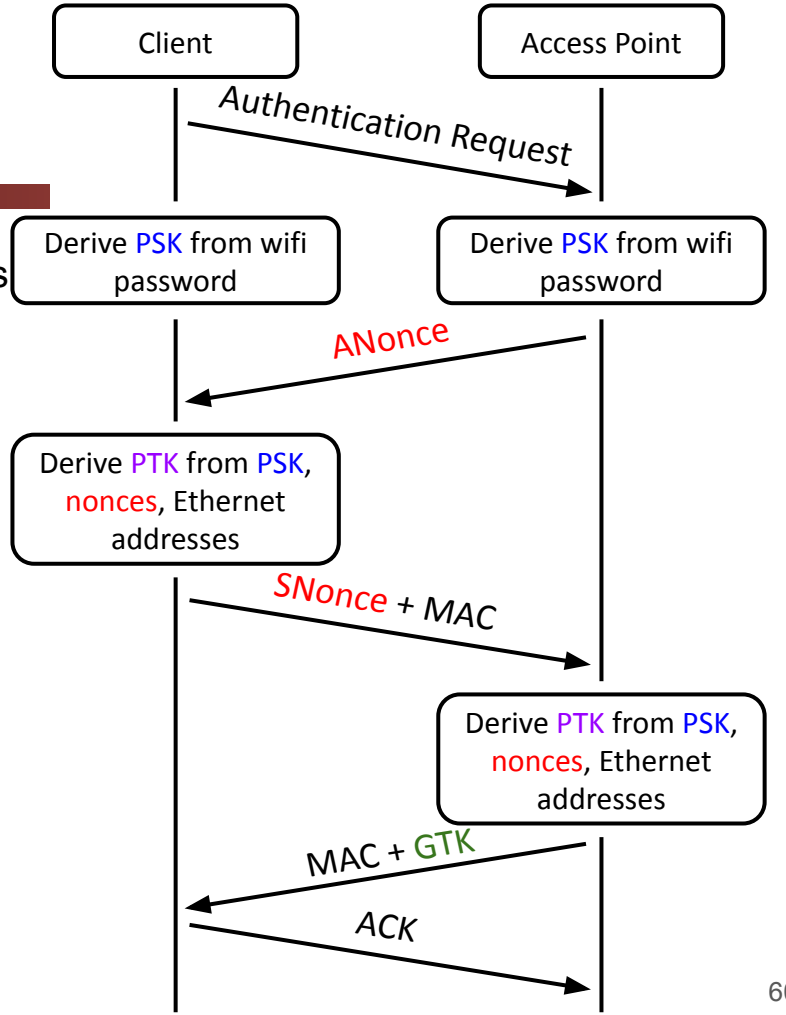


WPA Handshake

- Both sides derive secret keys for communication
  - Wi-Fi password → *PSK*
  - *PSK* + nonces + device addresses → *PTK*
  - The *PTK* is used to encrypt and authenticate all future communication
  - Note: The PTK is different for every user, because of the nonces
- The access point encrypts and sends the *GTK* to the client
  - The GTK is used for messages broadcast to the entire network
  - Everyone on the network uses the same GTK

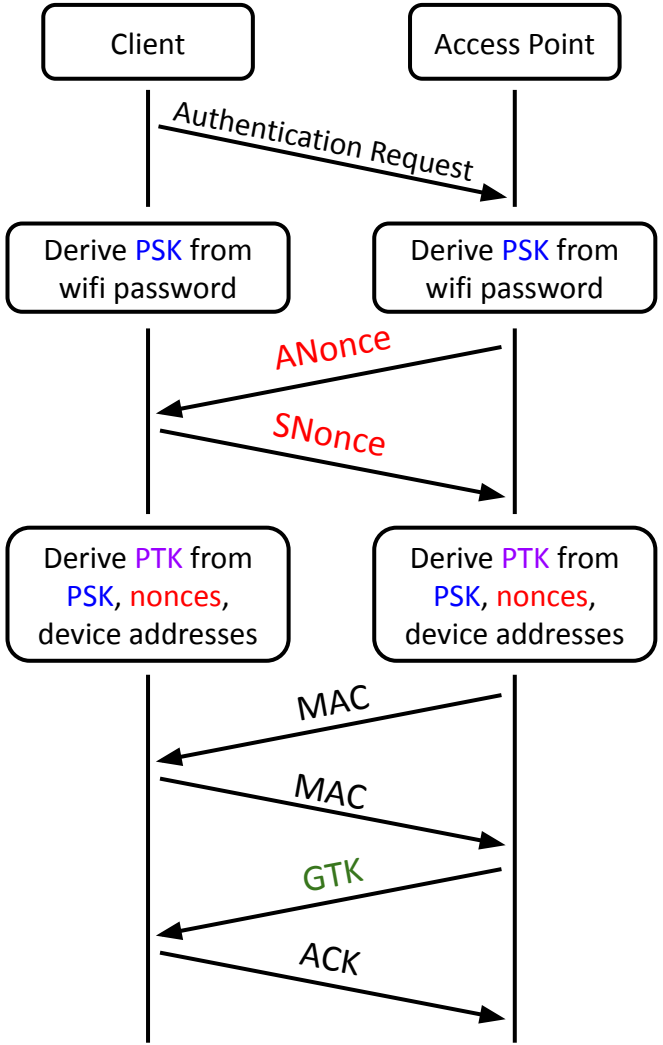
Optimized WPA 4-Way Handshake

1. The client sends an authentication request to the access point
2. Both use the password to derive the *PSK* (pre-shared key)
3. The AP sends *ANonce* to the client
4. The client generates *SNonce*, uses the *PSK*, nonces, and MAC addresses to derive the *PTK* (pairwise transport keys)
5. The client sends *SNonce* and its MAC to the AP
6. The AP uses the *PSK*, nonces, and MAC addresses to derive the *PTK* (pairwise transport keys)
7. The AP sends its MAC and *GTK* to the client
8. The client acknowledges receiving the GTK



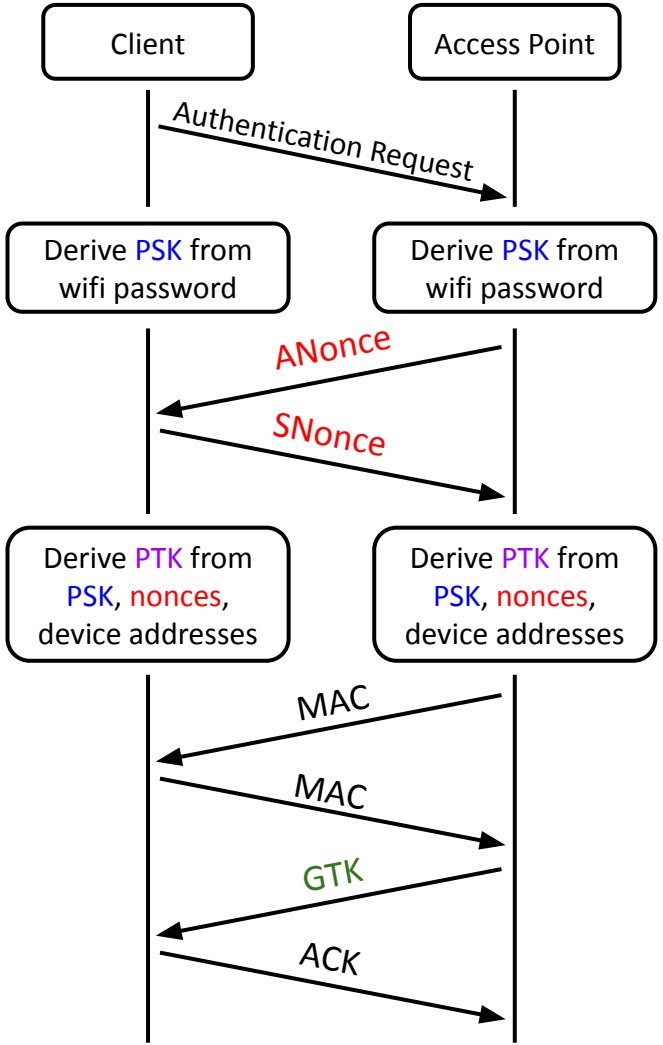
WPA-PSK Attacks

- **Rogue AP**: Pretend to be an AP, and offer your own *ANonce* to the client
  - If you know the password/PSK, you can complete the 4-way handshake with the client and become a MITM!



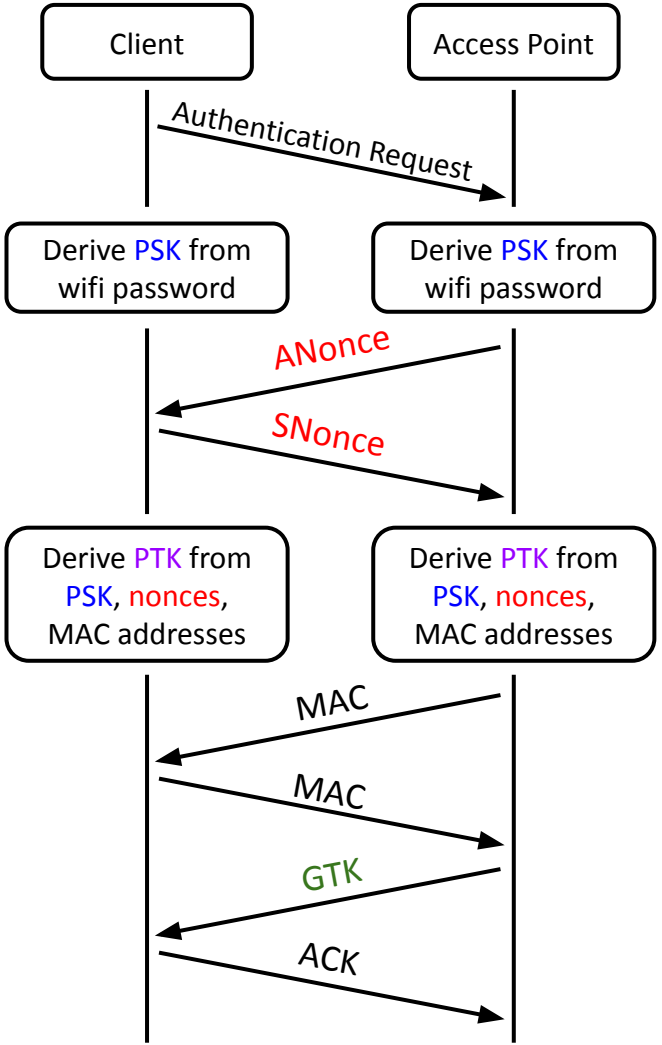
WPA-PSK Attacks

- **Offline brute-force attack**: People tend to choose bad passwords, and you have enough information to know if you guessed the password correctly
  - Nonces are sent unencrypted, and client and AP Ethernet addresses are public
  - Eavesdropper guesses a password and derives:
    - Wi-Fi password → *PSK*
    - *PSK* + nonces + device addresses → *PTK*
    - Eavesdropper checks that the MAC from the guess matches the MAC that was sent



WPA-PSK Attacks

- **No forward secrecy**: An eavesdropper who records the values of *ANonce* and *SNonce* can derive the key if they later learn the password or *PSK*
  - Compare to Diffie-Hellman: An eavesdropper can't learn the key even if the record g^a and g^b and later compromise Alice's computer



WPA-Enterprise

- Core issue: Every client starts with the same *PSK* to derive the *PTK*
  - Fix: Have each user use their own username and password, instead
    - This is the model that eduroam uses!

- Instead of using a PSK, use a key generated randomly by an auth server
  - For your client to trust the authentication server, you accept a digital certificate
  - Form a secure channel to the authentication server, which lets you enter your username and password
  - If the username and password are correct, the authentication server sends a one-time key to use instead of a PSK to both the client and the AP (also over a secure channel)

- The rest of the handshake proceeds normally

WPA-Enterprise Attacks

- WPA Enterprise defends against the previous attacks
  - **Rogue-AP attack**: The APs must authenticate themselves to the server, which the attacker can't do
  - **Brute-force attack**: The generated PSK replacement is long and random, too long to brute-force
  - **No forward secrecy**: The generated PSK replacement is used once and then discarded, so no information is retained that allows the PTK to be recovered later

- However, it is still vulnerable to attacks such as ARP or DHCP spoofing

Summary

- If an attacker is on your local-area network, it has a lot of power
  - Can read traffic meant for someone else
  - Can modify traffic between honest users
  - Can disconnect honest users from the network

- Core problem: There is little authentication/encryption in the network

- Defense: Fancier in-network hardware
  - ARP and DHCP attacks: Switches that filter and block traffic that looks suspicious
  - WPA attacks: Enterprise version that has cryptographic authentication

⇒ Still we rely on higher-layer protocols to provide encryption and authentication